MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 037 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

CASE IN POINT · CIVILIAN CUI

The FAR CUI Rule Is Coming for Contractors Who Never Saw DFARS

The proposed FAR CUI rule would put NIST 800-171 Rev 3, a 72-hour incident clock, and a new standard form into civilian agency contracts.

BY **MATTHEW DAVIS**

READING TIME · 7 MIN

FAR-CUI-RULE · CUI · CIVILIAN-AGENCIES · NIST-800-171 · INCIDENT-REPORTING

Picture a 60-person engineering firm that has never held a Department of Defense contract. It designs building systems under a prime contract with a civilian agency and does analysis work as a subcontractor on a larger integrator's Department of Homeland Security program. Its compliance vocabulary is FAR 52.204-21, the fifteen basic safeguarding requirements that come with federal contract information, and it has filed CMMC, DFARS 252.204-7012, and the 72-hour clock under someone else's problem. The FAR CUI rule, if finalized as proposed, would end that arrangement.

The direct answer for that firm is this. On June 23, 2026, the FAR Council published a proposed rule at 91 FR 37550, part of the Revolutionary FAR Overhaul, that would add a solicitation provision at FAR 52.240-6, Notice of Controlled Unclassified Information Requirements, and a contract clause at FAR 52.240-7, Controlled Unclassified Information, to civilian and defense contracts alike. Where an agency identifies CUI on a new standard form, the contractor's systems would have to meet NIST SP 800-171 Revision 3, report CUI incidents within 72 hours, and flow the clause to every subcontractor that touches the information. Comments closed July 23, 2026. The rule is not final, and nothing in it binds a contract today. It is still the clearest picture yet of civilian agency CUI requirements, and walking the firm through it shows where the cost lands.

FIELD COPY
ISSUE Nº 037
FAR CUI RULE

72

HOURS TO REPORT A CUI INCIDENT UNDER PROPOSED FAR 52.240-7, UP FROM 8 HOURS IN THE JANUARY 2025 DRAFT

90

DAYS A CONTRACTOR WOULD PRESERVE IMAGES OF AFFECTED SYSTEMS AFTER A REPORT, UNLESS THE GOVERNMENT DECLINES INTEREST FIRST

91 FR 37550

THE JUNE 23, 2026 PROPOSED RULE; COMMENTS CLOSED JULY 23, 2026, AND NO FINAL RULE HAS ISSUED

Its first encounter is a form, not a clause

Under the proposal, the firm would learn whether it holds CUI from the SF XXX, Controlled Unclassified Information (CUI) Requirements - the number is still a placeholder. The requiring activity fills it out for every requirement except COTS-only buys. If the agency marks Yes in Part A, the contracting officer attaches the form and inserts 52.240-7. If the agency marks No, the form goes in the contract file and the firm carries no CUI clause at all. The form names the categories involved, the authority behind each, whether and how the contractor must mark what it creates, and the organizationally defined parameters for Rev 3.

That design improves on the January 2025 draft. The earlier version, FAR Case 2017-016, proposed a separate clause, 52.204-YY, for contracts where the agency had marked No - a clause about identifying and reporting information that is potentially CUI, which would have followed the firm into work where nobody had found any. The June proposal deletes it. The clause says the contractor safeguards only the CUI identified on the form.

There is a residual duty, and it is narrower than the one it replaced. If the firm finds information it has knowledge indicating is CUI but that is missing from the form or improperly marked, it would notify the contracting officer within 72 hours and safeguard that information until the officer decides. If the agency wants the firm to keep handling it, the contract gets modified and the officer must consider a request for equitable adjustment. The firm is not the one designating anything, a point this newsletter made in what actually makes a file CUI, and the proposed rule holds to it.

The baseline gets priced in the proposal, not after award

The part of the rule that moves money arrives before the firm has won anything. Under 52.240-6(d), an offeror that does not meet every requirement of 52.240-7 must include with its offer a disclosure listing each unmet requirement and a plan of action and milestones to close it. The contracting officer then follows agency procedures to decide whether a waiver is possible.

Under the proposed rule, a civilian contractor's security gap stops being an internal to-do list and becomes part of its offer.

What the firm would be measured against is specific. Non-federal systems handling the identified CUI would meet NIST SP 800-171 Rev 3 using the organizationally defined parameters published by the DoD CIO, plus any CUI Specified requirements the form names, plus NIST SP 800-172 enhancements only where the agency flags a critical program or high-value asset. Any cloud service that stores, processes, or transmits the CUI would need security equivalent to the FedRAMP Moderate baseline. The system security plan, including any external service provider handling CUI, and its associated plans of action must be available to the government on request. How Rev 3 differs from the Rev 2 requirements defense contractors know is its own subject, covered in our Rev 2 versus Rev 3 comparison.

◆ WHAT THE PROPOSED RULE WOULD NOT REACH

Contracts solely for commercially available off-the-shelf items are excluded from the clause. So is any contract where the agency marks No in Part A of the new standard form. The clause also names two out-of-scope assets - an endpoint running a virtual desktop client configured so CUI never goes beyond keyboard, video, and mouse, and commercial communications networks that carry government and non-government traffic alike.

For pricing a bid, that means the clause scan this newsletter recommends for reading a solicitation's compliance clauses before you bid now applies to civilian solicitations too. A solicitation whose form is marked Yes carries the cost of an assessed Rev 3 posture, a FedRAMP Moderate equivalent cloud, and whatever enclave work keeps the scope sane. One marked No does not. Those are different price points for work that may look identical in the statement of work.

Seventy-two hours, to CISA, and a copy up the chain

The January 2025 draft would have required reporting CUI incidents within eight hours. Commenters pushed back, and the June proposal sets 72 hours from discovery, citing alignment with DFARS 252.204-7012 and the Cyber Incident Reporting for Critical Infrastructure Act. The mechanics of running that clock are the same discipline laid out in the 72-hour clock, hour by hour; what changes for our firm is where the report goes. Non-DoD contracts would report to CISA's incident reporting portal, DoD contracts to DIBNet, and in either case the contractor notifies the contracting officer and, as a subcontractor, the next higher-tier contractor. A first report carries whatever data elements are available, with a follow-up once the investigation is substantially complete.

The definition narrows too. A CUI incident means unauthorized disclosure, improper modification or destruction, or unauthorized access to the system holding the CUI. A mismarked document is not an incident unless the mishandling actually caused one of those outcomes.

The firm's DHS subcontract is where flow-down becomes concrete. The prime would have to put the substance of 52.240-7 into every subcontract, at any tier, that requires access to identified CUI, without alteration except to name the parties, along with the form information telling the sub what CUI applies. Commercial products and services are included; only COTS items are excluded. That subcontractor would report incidents directly to the government.

The day it signs a DoD subcontract, it runs two baselines

Now suppose the firm takes its first defense subcontract. DFARS 252.204-7012 still binds NIST SP 800-171 Rev 2, held there by DoD class deviation, and SPRS still scores Rev 2. CMMC Phase II assessments remain suspended pending the Reform Task Force review, but 7012 did not pause. The proposed FAR clause, meanwhile, would bind Rev 3, and the rule says its parameters align to values DoD intends to codify in 32 CFR part 170 through its own rulemaking. Until those two tracks meet, a company holding both portfolios would maintain one CUI environment evidenced against two revisions, report to two portals on the same 72-hour window, and read two sets of clauses in every teaming agreement.

The economical move is to decide the boundary once. A single enclave that holds both civilian and defense CUI, documented so each safeguard is evidenced against its Rev 2 and its Rev 3 identifier without the two numbering schemes collapsing into one, is one build and one set of artifacts instead of two environments stood up a year apart. That is the approach behind MacTech's NIST 800-171 compliance work, which ties each requirement to the artifact that proves it, and a readiness assessment is a quick way to see where a firm stands before any agency asks.

The firm in this example does not need to rebuild anything for a rule that has not issued. What it cannot afford is to learn its answer at the worst moment. Somewhere in its current book is a contract whose information an agency would plausibly list on that form, and the recompete for it will likely be the first solicitation to carry 52.240-6. The disclosure that provision demands can be a short list or a long one. Which it is gets decided in the months before that solicitation posts, not in the week the proposal is due. ◆

MORE ISSUES

mactechsolutionsllc.com/maczine

new field copies with every merge

WORK WITH US

CMMC readiness · CUI enclaves · RMF

mactechsolutionsllc.com/contact

MACZINE

Written, reviewed and versioned in the open.

Published from Git, reviewed like code.